

 CONFIDENCIAL

Reporte de Vulnerabilidad

Security Misconfiguration — Divulgación de información en cabeceras y ausencia de header de hardening

ID del Ticket	VULN-2026-002
Objetivo	github.com (Programa de Bug Bounty público de GitHub)
Severidad	BAJA CVSS v3.1 base 5.3 · severidad efectiva Baja/Informativa
Tipo	Security Misconfiguration — CWE-200 / CWE-693
Metodología	Análisis estrictamente pasivo (observación de tráfico HTTP)
Analista	J. M. F. · jmf01111974@gmail.com
Fecha del reporte	04 de octubre de 2026
Versión	1.0

Contenido

1. Resumen Ejecutivo	pág. 2
2. Detalles Técnicos	pág. 2
3. Métricas CVSS	pág. 3
4. Prueba de Concepto (PoC) pasiva	pág. 4
5. Recomendaciones de Remediación	pág. 5
6. Alcance, ética y referencias	pág. 6

Evaluación realizada sobre un objetivo incluido en un programa de divulgación de vulnerabilidades público. No se ejecutó ninguna acción intrusiva: únicamente se observó el tráfico HTTP generado por la navegación normal.

1. Resumen Ejecutivo

Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

Mediante la simple observación de las respuestas que el servidor envía a cualquier visitante, se detectó que las páginas de `github.com` **revelan datos internos de su infraestructura** (la región del centro de datos que atiende la petición y un identificador interno de la solicitud) y que **omiten una cabecera de seguridad recomendada** (`Permissions-Policy`) que ayuda a limitar funciones sensibles del navegador.

¿Por qué importa para el negocio?

Se trata de un hallazgo de **baja criticidad y de "endurecimiento" (hardening)**, no de una brecha explotable por sí sola. Los datos expuestos son metadatos de infraestructura de baja sensibilidad; su valor es que podrían facilitar las fases de reconocimiento de un atacante. La ausencia de la cabecera reduce una capa de defensa en profundidad del navegador. **No se expusieron datos de usuarios ni credenciales.**

¿Qué tan grave es?

Severidad Baja. El puntaje CVSS base mecánico es 5.3, pero —por tratarse de información de baja sensibilidad y de una medida de defensa en profundidad— la severidad efectiva de triaje es **Baja/Informativa**. Durante la evaluación se confirmó además que la postura general del objetivo es **sólida**: aplica HSTS con *preload*, CSP estricta, protección anti-clickjacking y cookies de sesión correctamente protegidas.

¿Qué hay que hacer?

Añadir la cabecera `Permissions-Policy` y **reducir al mínimo** los encabezados que revelan infraestructura. Es una corrección de **bajo esfuerzo**, sin impacto en la funcionalidad.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Divulgación de metadatos de infraestructura + hardening faltante	Baja	Bajo	Planificada (próximo ciclo)

2. Detalles Técnicos

Audiencia: equipo de desarrollo y administradores de plataforma.

2.1 Metodología (estrictamente pasiva)

Se navegó el objetivo con un navegador basado en Chromium y se observaron, mediante el panel **Red** → **Encabezados** del inspector (equivalente al historial de un proxy tipo Burp/ZAP), las respuestas HTTP generadas por peticiones `GET` naturales. **No se realizó fuzzing, inyección, manipulación de parámetros ni ninguna petición activa.** Todos los datos observados son los que el servidor entrega a cualquier cliente.

2.2 Hallazgos

a) Divulgación de información de infraestructura en cabeceras (CWE-200). Las respuestas incluyen de forma sistemática:

- `X-GitHub-Edge-Region: iad` — revela el nodo de borde / región del centro de datos que sirve la petición (`iad` = Ashburn, Virginia, EE. UU.).

- **X-GitHub-Request-Id: C002:274EDF:701657:9590FC:6AC29795** — identificador interno de la petición en la plataforma.

Son datos de baja sensibilidad, pero no son necesarios para el cliente y aportan información útil al reconocimiento previo a un ataque.

b) Ausencia de la cabecera **Permissions-Policy (CWE-693).** Ninguna de las respuestas evaluadas (`/`, `/login`, `api.github.com`, `raw.githubusercontent.com`) define **Permissions-Policy**. Esta cabecera permite restringir el acceso del sitio y de sus iframes a funciones sensibles del navegador (cámara, micrófono, geolocalización, etc.); su ausencia elimina una capa de defensa en profundidad.

c) Observación menor — cookie `_octo` sin **HttpOnly.** La cookie `_octo` se emite con **Secure** y **SameSite=Lax** pero sin **HttpOnly**, por lo que es accesible desde JavaScript. Es un valor de analítica/CSRF de lado cliente (no de sesión), por lo que el impacto es mínimo; se documenta por completitud.

✓ **Controles correctamente implementados** (confirmados en la misma captura): HSTS `max-age=31536000; includeSubdomains; preload`; CSP estricta con `default-src 'none'` y `frame-ancestors 'none'`; `X-Frame-Options: deny`; `X-Content-Type-Options: nosniff`; cabecera **Server** sin versión; cookies de sesión `_gh_sess` y `logged_in` con **Secure** + **HttpOnly** + **SameSite**.

2.3 Activos y alcance afectado

Objetivo	Programa de Bug Bounty público de GitHub (bounty.github.com)
Hosts observados	<code>github.com</code> , <code>api.github.com</code> , <code>raw.githubusercontent.com</code>
Cabeceras implicadas	<code>X-GitHub-Edge-Region</code> , <code>X-GitHub-Request-Id</code> , Permissions-Policy (ausente)
Dato sensible involucrado	Ninguno de usuario; solo metadatos de infraestructura de baja sensibilidad

2.4 Causa raíz

Configuración de la capa de borde/aplicación que (1) propaga a la respuesta encabezados de diagnóstico interno y (2) no incluye la política de permisos del navegador en el conjunto de cabeceras de seguridad estándar.

3. Métricas CVSS

Puntuación objetiva del riesgo técnico, según CVSS v3.1, con lectura transparente.

CVSS Base Score	Severidad base	Vector
5.3	MEDIA	<code>CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N</code>

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	Network (N)	Observable de forma remota en cada respuesta HTTP.
Attack Complexity (AC)	Low (L)	No requiere condiciones especiales: basta con leer las cabeceras.

Privileges Required (PR)	None (N)	No requiere autenticación; los datos se envían a cualquier visitante.
User Interaction (UI)	None (N)	No requiere acción de ninguna víctima.
Scope (S)	Unchanged (U)	El impacto no cambia de autoridad de seguridad.
Confidentiality (C)	Low (L)	Divulgación de metadatos de infraestructura de baja sensibilidad.
Integrity (I)	None (N)	No permite modificar datos.
Availability (A)	None (N)	No afecta la disponibilidad.

Nota de criterio (transparencia): el puntaje mecánico es **5.3 (Media)** por tratar la divulgación como impacto de confidencialidad **C:L**. Dado que la información es de muy baja sensibilidad y que la ausencia de **Permissions-Policy** es una medida de **defensa en profundidad sin impacto directo**, una lectura conservadora (**C:N**) resulta en **0.0 (Informativo)**. La **severidad efectiva reportada es Baja**, acorde a cómo un programa de Bug Bounty triaría este tipo de hallazgo.

Verificable en: <https://www.first.org/cvss/calculator/3.1>

4. Prueba de Concepto (PoC) pasiva

Reproducción paso a paso mediante observación. Cualquier persona puede replicarla sin enviar peticiones activas.

4.1 Requisitos previos

- Un navegador con herramientas de desarrollo (o un proxy en modo pasivo tipo Burp/ZAP).
- Opcional: `curl` para confirmar las cabeceras desde consola.

4.2 Pasos de reproducción

Paso 1 — Abrir el inspector antes de navegar. En el navegador, abrir *Herramientas de desarrollo* → *pestaña Red* (F12) y marcar «conservar registro».

Paso 2 — Navegar al objetivo. Cargar <https://github.com/> con una petición **GET** normal.

Paso 3 — Inspeccionar los encabezados de respuesta. Seleccionar el documento principal y leer la sección «Encabezados de respuesta». Se observan **X-GitHub-Edge-Region** y **X-GitHub-Request-Id**, y la **ausencia** de **Permissions-Policy**.

Confirmación por consola (equivalente pasivo, solo lectura):

```
# Únicamente se leen las cabeceras de una respuesta GET natural
curl -sSI https://github.com/ | grep -Ei "x-github-edge-region|x-github-request-id|permissions-policy|strict-transport|content-security"
# Salida real observada:
# strict-transport-security: max-age=31536000; includeSubdomains; preload
# content-security-policy: default-src 'none'; ... ; frame-ancestors 'none'
# x-github-edge-region: iad
# x-github-request-id: C002:274EDF:701657:9590FC:6AC29795
# (permissions-policy: no aparece -> AUSENTE)
```

4.3 Evidencia

GET https://github.com/ → HTTP/2 200 OK [captura pasiva – Chromium / panel Red · Encabezados de respuesta]

Encabezados	Carga útil	Vista previa	Respuesta	Cookies
ENCABEZADOS DE RESPUESTA				
server	github.com (sin versión – correcto)			
strict-transport-security	max-age=31536000; includeSubdomains; preload ✓			
content-security-policy	default-src 'none'; ... ; frame-ancestors 'none'; upgrade-insecure-requests ✓			
x-frame-options	deny ✓			
x-content-type-options	nosniff ✓			
referrer-policy	origin-when-cross-origin, strict-origin-when-cross-origin			
x-github-edge-region	iad HALLAZGO · divulgación de infraestructura (CWE-200)			
x-github-request-id	C002:274EDF:701657:9590FC:6AC29795 Id interno			
permissions-policy	<AUSENTE> HALLAZGO · header de hardening faltante (CWE-693)			
x-xss-protection	0 (deshabilitado – correcto en navegadores modernos)			
content-type	text/html; charset=utf-8			
date	Sun, 04 Oct 2026 18:14:32 GMT			
COOKIES (PESTAÑA APLICACIÓN / ALMACENAMIENTO)				
_gh_sess	Secure ✓ · HttpOnly ✓ · SameSite=Lax ✓ (cookie de sesión – correcta)			
logged_in	Secure ✓ · HttpOnly ✓ · SameSite=Lax ✓			
_octo	Secure ✓ · HttpOnly x · SameSite=Lax observación menor (no es cookie de sesión)			

Evidencia 1 — Panel «Red → Encabezados» del inspector a partir de la captura real de `GET https://github.com/`. En rojo, los encabezados que divulgan infraestructura; en amarillo, el header de hardening ausente y la cookie `_octo` sin `HttpOnly`; en verde, los controles correctamente implementados.

[Skip to content](#)

Navigation Menu



[Sign in](#)

Platform

AI CODE CREATION

GitHub CopilotWrite better code with AI

GitHub Copilot appDirect agents from issue to merge

MCP RegistryIntegrate external tools

DEVELOPER WORKFLOWS

ActionsAutomate any workflow

CodespacesInstant dev environments

IssuesPlan and track work

Code ReviewManage code changes

Code QualityEnforce quality at merge

APPLICATION SECURITY

GitHub Advanced SecurityFind and fix vulnerabilities

Code securitySecure your code as you build

Secret protectionStop leaks before they start

EXPLORE

Why GitHub

Documentation

Blog

Changelog

Marketplace

[View all features](#)

Solutions

BY COMPANY SIZE

Enterprises

Small and medium teams

Startups

Nonprofits

BY USE CASE

App Modernization

DevSecOps

DevOps

CI/CD

[View all use cases](#)

Evidencia 2 — Captura de la página objetivo (`github.com`) cargada durante la observación pasiva, como contexto del activo evaluado.

4.4 Resultado esperado vs. obtenido

Esperado (endurecido)	Obtenido
-----------------------	----------

Documento confidencial — Reconocimiento pasivo · Programa Bug Bounty GitHub | Página 5 de 7

Respuestas sin encabezados de diagnóstico interno y con `Permissions-Policy` definida.

Se exponen `X-GitHub-Edge-Region` / `X-GitHub-Request-Id` y falta `Permissions-Policy`.

⚠ Nota ética y de alcance: toda la actividad fue **pasiva** sobre un objetivo de un programa de divulgación público. No se intentó acceder a datos de terceros, autenticarse, ni enviar cargas maliciosas. La evidencia contiene solo datos que el servidor entrega a cualquier visitante.

5. Recomendaciones de Remediación

Audiencia: equipo que gestiona la capa de borde y la aplicación.

5.1 Solución recomendada

Definir la cabecera `Permissions-Policy` con una política restrictiva por defecto, deshabilitando las funciones no utilizadas:

```
# Ejemplo restrictivo (ajustar a las funciones realmente necesarias)
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
```

Minimizar los encabezados que revelan infraestructura en la capa de borde (CDN/reverse proxy), suprimiéndolos en respuestas de cara al público o reemplazándolos por un identificador opaco sólo correlacionable internamente.

```
# Nginx – eliminar cabeceras de diagnóstico de la respuesta pública
proxy_hide_header X-GitHub-Edge-Region;
# mantener un request-id interno pero no exponer el formato interno al cliente
```

5.2 Mitigaciones y buenas prácticas

- Incluir `Permissions-Policy` en la plantilla estándar de cabeceras de seguridad de todos los servicios (defensa en profundidad uniforme).
- Evaluar marcar `_octo` como `HttpOnly` si su uso de lado cliente lo permite; de lo contrario, documentar la excepción.
- Revisión periódica de cabeceras con herramientas de análisis (p. ej. securityheaders.com) integradas en CI/CD.

5.3 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Añadir <code>Permissions-Policy</code> a la plantilla de cabeceras	Plataforma / Edge	Baja	Próximo ciclo	Pendiente
Suprimir/ofuscar cabeceras de diagnóstico públicas	Infraestructura	Baja	Próximo ciclo	Pendiente
Re-test de verificación	Analista de seguridad	Baja	Tras el fix	Pendiente

5.4 Verificación (re-test)

Repetir el Paso 3 de la PoC y confirmar que las respuestas incluyen `Permissions-Policy` y ya no exponen `X-GitHub-Edge-Region` ni el identificador interno con su formato original.

6. Alcance, ética y referencias

Declaración de alcance y ética

Esta evaluación se limitó a la **observación pasiva** de respuestas HTTP de un objetivo perteneciente a un **programa de divulgación de vulnerabilidades público**. No se ejecutaron pruebas activas, de denegación de servicio, ni acceso a cuentas o datos de terceros. Antes de cualquier prueba intrusiva debe revisarse y respetarse la política del programa (*Safe Harbor*, alcance y reglas de interacción).

Referencias

- Programa de Bug Bounty de GitHub: <https://bounty.github.com/>
- CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor: <https://cwe.mitre.org/data/definitions/200.html>
- CWE-693 — Protection Mechanism Failure: <https://cwe.mitre.org/data/definitions/693.html>
- OWASP Top 10 (2021) — A05 Security Misconfiguration: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- MDN — Permissions-Policy: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy>
- CVSS v3.1 Calculator (FIRST): <https://www.first.org/cvss/calculator/3.1>

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-10-04	J. M. F.	Creación del reporte de reconocimiento pasivo.

 Documento confidencial — uso académico / profesional autorizado. Reconocimiento pasivo sobre objetivo de programa público.